

10.2

TYPES OF IDS

- Detecting Intrusions
- IDS Types
- IDS Components
- HIDS
- NIDS
- Indicators
- WIPS



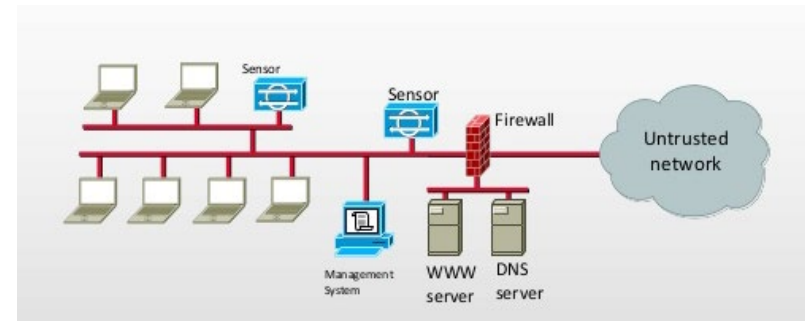
TYPES OF INTRUSION DETECTION SYSTEMS

- **Network-Based Intrusion Detection Systems**

- NIDS / NIPS
- Black box on network in promiscuous mode
- Detects malicious activity on the network
- Does not detect anything going on in a host

- **Host-Based Intrusion Detection Systems**

- HIDS / HIPS
- Audits for events on a specific host
- Requires overhead to monitor every system event
- Only detects activity inside the host
- Does not detect anything happening on the network



WAYS TO DETECT INTRUSIONS

■ Signature-based

- Can only detect known attacks for which a signature has previously been created
- Must regularly download signatures from the vendor
- Is at risk of false negatives
- More commonly used by IDS

■ Anomaly-based

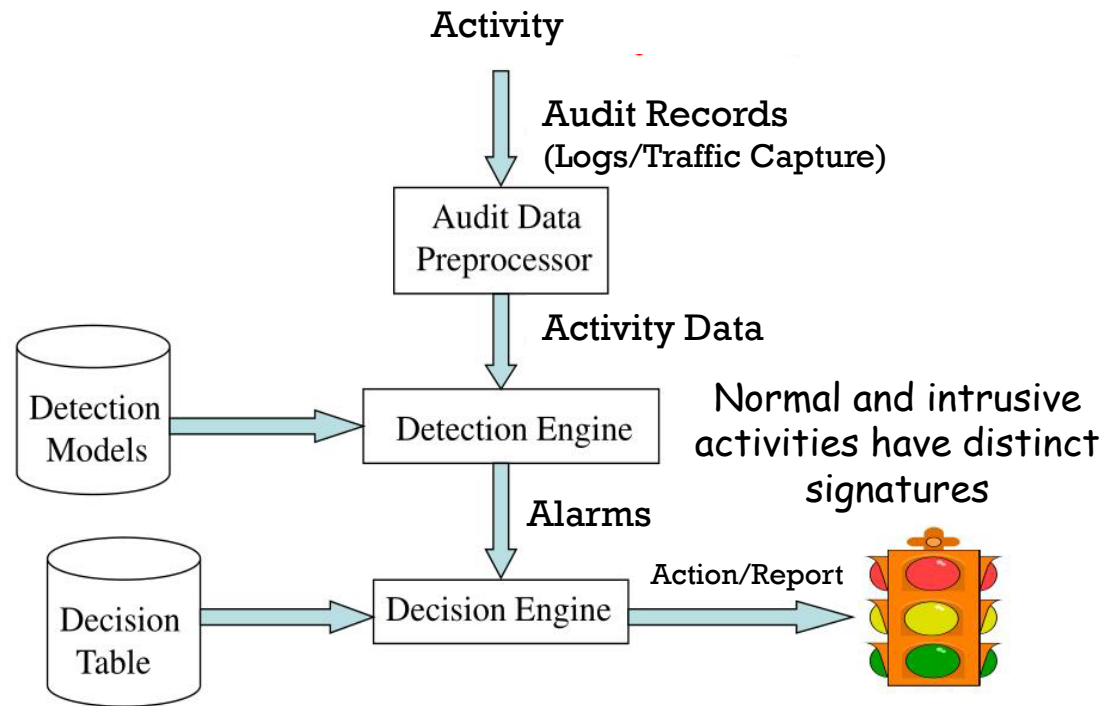
- Can identify unknown attacks
- Must pre-create a baseline of “normal” network traffic
 - Capture network traffic for about two weeks
 - Analyze protocols and usage statistics to identify “normal”
- Is at risk of false positives
- More commonly used by IPS

■ Protocol Anomaly Detection

- Uses models to determine anomalies in how TCP/IP specifications are deployed



IDS COMPONENTS



IDS RESULTS

- **True Positive**
 - There truly was a security incident
 - A real attack was detected
- **True Negative**
 - There truly was NOT any incident
 - Most desirable! Security controls are working!
- **False Positive**
 - False alarm
 - An incident was reported, but it didn't actually happen
 - Too many false positives can become annoying
- **False Negative**
 - A security incident actually happened, but was not detected
 - IDS falsely reports that everything is ok
 - This is the most serious and dangerous of all!



IDS RESULTS EXAMPLE

True negative



False positive



False negative



True positive



HOST-BASED IDS/IPS (HIDS/HIPS)

- Only activities inside the host are monitored:
 - File activity
 - Processes
 - Logons
 - Privileged actions
 - User account changes
 - Software installation/deletion
- Host-based IDS/IPS **does not monitor network activity**
 - Port and vulnerability scans, denial-of-service attacks against the host
- **HIDS logs** suspicious activities
- **HIPS prevents** suspicious activities



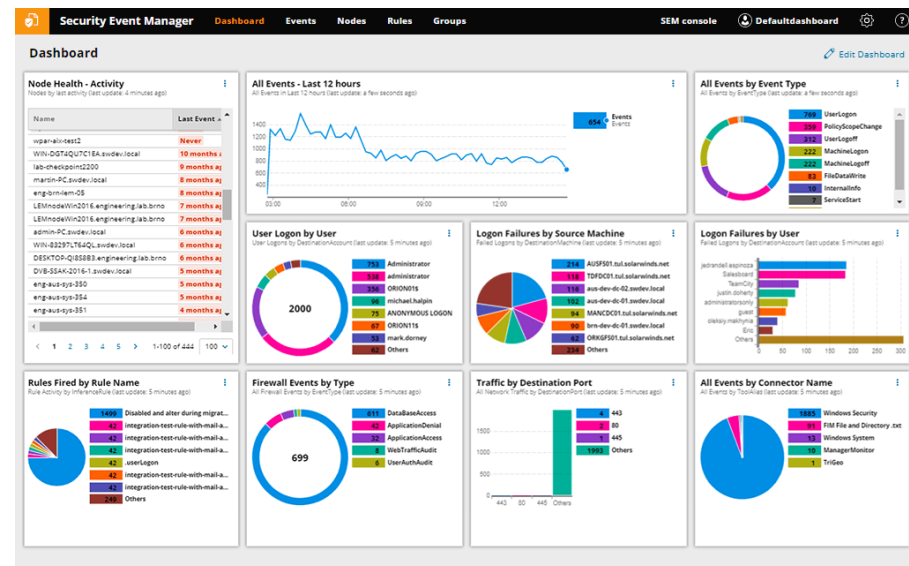
HIDS/HIPS PRODUCTS

- SolarWinds Log and Event Manager
- ManageEngine Log 360
- OSSEC
- Samhain
- Fail2Ban
- AIDE
- Sagan
- Security Onion
- Splunk
- Symantec Endpoint Protection



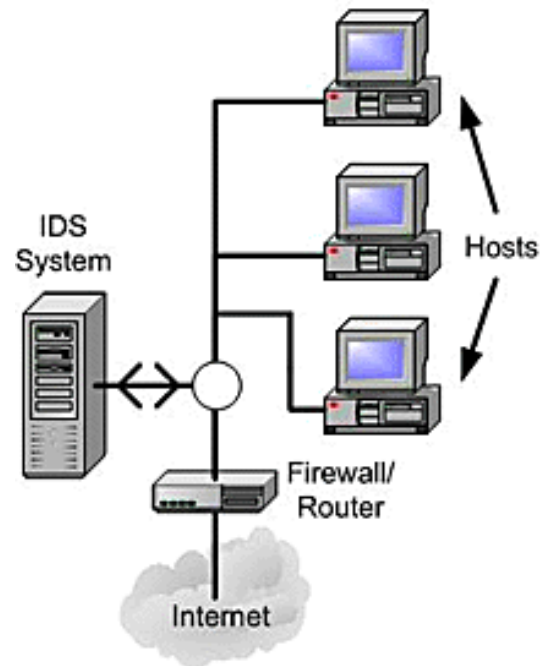
NIDS EXAMPLE PRODUCTS

- SolarWinds
- Bro
- OSSEC
- Snort
- Suricata
- Security Onion
- Open WIPS-NG
- Sagan
- McAfee Network Security Platform
- Palo Alto Networks

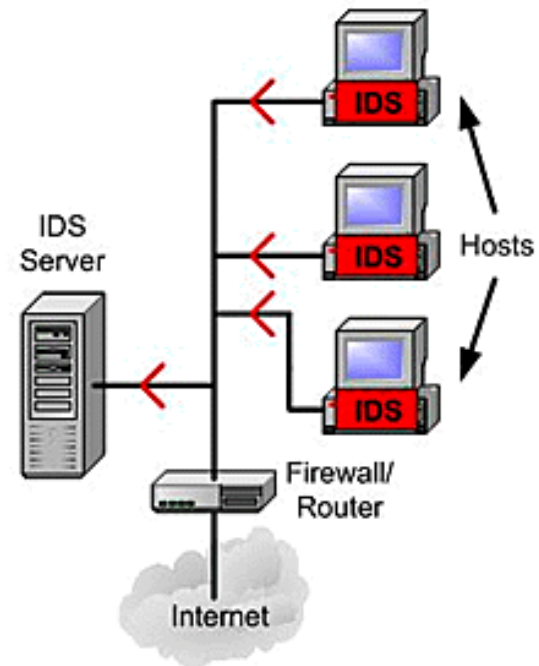


NIDS VS HIDS

Network Based IDS



Host Based IDS

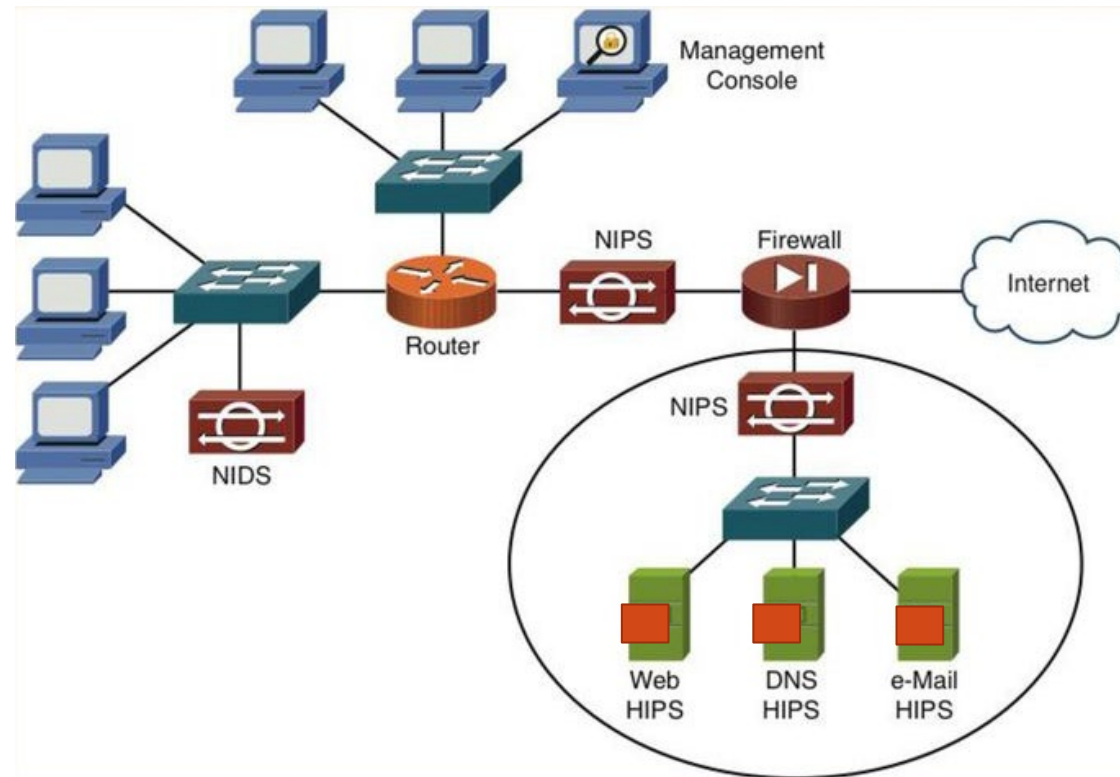


NETWORK INTRUSION PREVENTION (NIPS)

- A NIPS is an active monitoring and control system
- A network packet comes from Internet and passes through Firewall
- The packet passes through IDS and undergoes signature comparison
- If there is no match the packet is sent to the switch and into enterprise network
- If there is a match:
 - An alarm sent and logged
 - The packet is sent through anomaly detection and stateful protocol analysis
 - Connections from the source are cut
 - The packet is dropped



NIDS, NIPS, HIDS/HIPS PLACEMENT



✓ INDICATORS OF NETWORK INTRUSIONS

- Ongoing probes of services on your network
- Unusual locations connecting to your network
- Ongoing remote login attempts
- Unauthorized data exfiltration
- Hosts with unexpected outbound connections
- Outbound connections to unusual destination ports



✓ INDICATORS OF SYSTEM INTRUSIONS

- New/unfamiliar files or programs detected
- Unfamiliar files names
- Files that are missing
- File permissions changed
- Files sizes changed unexpectedly
- Rogue files not on master list of signed files



INDICATORS OF SYSTEM INTRUSIONS (CONT'D)

- Incomplete/short logs
- Logs that are missing/have incorrect permissions
- Random data in log files that might cause DoS or a service crash
- Slow performance of the system
- Graphic displays/text messages that are unusual
- Alterations to system software/configuration files
- System crashes/reboots
- Processes that are unfamiliar



SNORT

- Snort Overview
- Running Snort
- Snort Rules



SNORT

- Popular open source **NIDS**
- Runs in Linux or Windows
- You can create your own custom rules
- **Will not block the connection or drop the packet**
- Evaluates the entire packet against all alert rules
- **Logs any matches it finds**
- Allows packet to continue onward to its destination



SNORT MODES

- **Packet Sniffer**

- SNORT's packet sniffer mode means the software will read IP packets then display them to the user on its console

- **Packet Logger**

- In packet logger mode, SNORT will log all IP packets that visit the network
- The network admin can then see who has visited their network and gain insight into the OS and protocols they were using

- **NIDS (Network Intrusion and Prevention Detection System)**

- In NIDS mode, SNORT will **only log packets that are considered malicious**
- It does this using the preset characteristics of malicious packets, which are defined in its rules
- The action that SNORT takes is also defined in the rules the network admin sets out



SNORT CONFIGURATION FILE

- Snort.conf
- Located in:
 - /etc/snort on Linux
 - C:\snort\etc in Windows

```
alert tcp $EXTERNAL_NET 1000:1300 -> $HOME_NET 146 ( msg:"MALWARE-  
BACKDOOR Infector 1.6 Client to Server Connection Request";  
flow:to_server,established; content:"FC "; metadata:ruleset community;  
reference:nessus,11157; classtype:misc-activity; sid:121; rev:14; )  
alert tcp $HOME_NET 31785 -> $EXTERNAL_NET any ( msg:"MALWARE-BACKDOOR  
HackAttack 1.20 Connect"; flow:to_client,established; content:"host";  
metadata:ruleset community; classtype:misc-activity; sid:141; rev:10; )  
alert tcp $EXTERNAL_NET any -> $HOME_NET 21 ( msg:"PROTOCOL-FTP ADMw0rm  
ftp login attempt"; flow:to_server,established; content:"USER",nocase;  
content:"w0rm",distance 1,nocase; pcre:"/^USER\s+w0rm/ims";  
metadata:ruleset community; service:ftp; classtype:suspicious-login;  
sid:144; rev:16; )  
alert tcp $HOME_NET 30100:30102 -> $EXTERNAL_NET any ( msg:"MALWARE-  
BACKDOOR NetSphere access"; flow:to_client,established;  
content:"NetSphere"; metadata:ruleset community; classtype:trojan-  
activity; sid:146; rev:13; )
```



SPECIFYING THE SNORT OPERATIONAL MODE

- Snort as Sniffer ---> `snort -v`
- Snort as Packet logger ---> `snort -l`
- Snort as NIDS ---> `snort -A` or `snort -c <path_to_conf_file>`



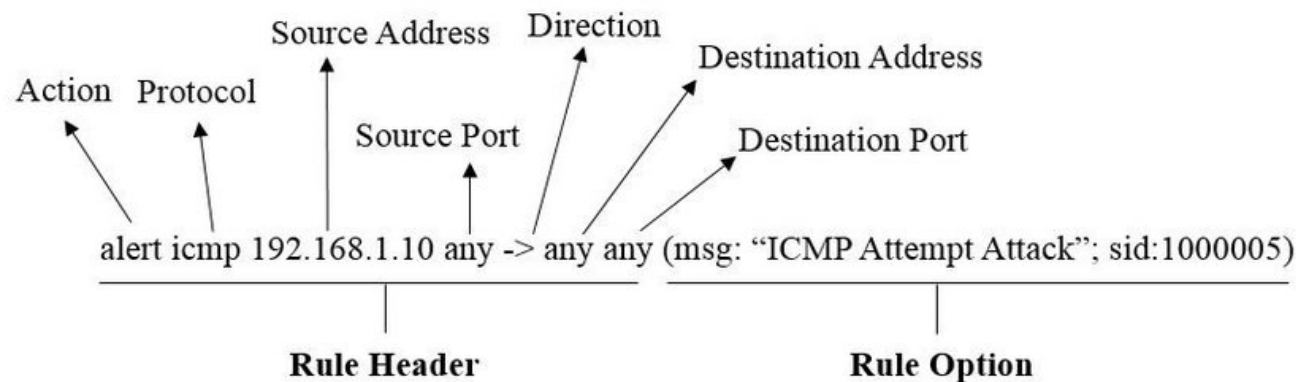
SNORT RULES

- Monitored protocols:
 - TCP
 - UDP
 - ICMP
- Rule Actions
 - Alert
 - Pass
 - Log



UNDERSTANDING SNORT RULES

- A security analyst should be able to read Snort IDS rules and pick out generic content such as:
 - The type of protocol covered by the signature
 - The port to be analyzed
 - The direction of traffic flow



BREAKING DOWN A SNORT RULE

```
alert icmp any any -> &HOME_NET any (msg:"ICMP test"; sid:1000001;  
rev:1; classtype:icmp-event;)
```

Rule part	Information
alert icmp any any -> \$HOME_NET any	Rule Header ↓
alert	Rule action. Snort will generate an alert when the set condition is met.
any (1st)	Source IP. Snort will look at all sources
any (2nd)	Source port. Snort will look at all ports
->	Direction. From source to destination; (<i>source -> destination</i>)



BREAKING DOWN A SNORT RULE (CONT'D)

```
alert icmp any any -> &HOME_NET any (msg:"ICMP test"; sid:1000001;  
rev:1; classtype:icmp-event;)
```

Rule part	Information
&HOME_NET	Destination IP. We are using the HOME_NET value from the snort.conf file which means a variable that defines the network or networks you are trying to protect.
any (3rd)	Destination port. Snort will look at all ports on the protected network



BREAKING DOWN A SNORT RULE (CONT'D)

```
alert icmp any any -> &HOME_NET any (msg:"ICMP test"; sid:1000001;  
rev:1; classtype:icmp-event;)
```

Rule part	Information
msg:"ICMP test"	Snort will include this message with the alert
sid:1000001	Snort rule ID. All numbers below 1,000,000 are reserved If you create your own rule, assign it with any available number greater than 1,000,000



BREAKING DOWN A SNORT RULE (CONT'D)

```
alert icmp any any -> &HOME_NET any (msg:"ICMP test"; sid:1000001;  
rev:1; classtype:icmp-event;)
```

Rule part	Information
rev:1	• Revision number. • This option allows for easier rule maintenance
classtype:icmp-event	• Categorizes the rule as an "icmp-event", one of the predefined Snort categories. Categories help with organizing rules



SYSTEM LOGS

- OS Logs
- Syslog

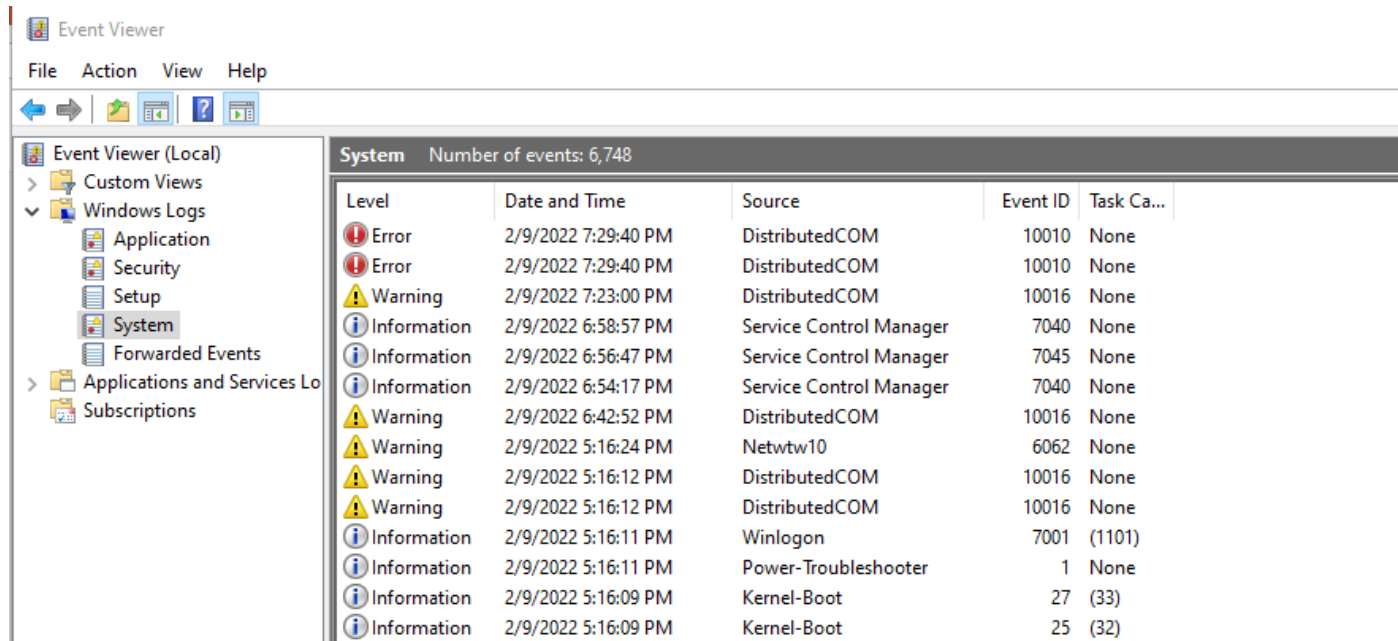


SYSTEM LOGS

- Nearly all devices have a system log
 - Windows Event Viewer
 - Linux has many logs located in /var/log
 - Most routers, switches, firewalls and other network devices have their own logs
- Log events can be sent to a central Syslog server
 - On Windows, install the Syslog server's client software
 - On Linux, edit /etc/syslog.conf to point to the Syslog server
- Logs can also be queried by a SIEM or IDS



SYSTEM LOG EXAMPLE



The screenshot shows the Windows Event Viewer application. The left pane displays the 'Event Viewer (Local)' tree with 'System' selected under 'Windows Logs'. The right pane shows a list of 15 events from the System log. The events are sorted by date and time, showing a mix of errors, warnings, and information messages from various sources like DistributedCOM, Service Control Manager, Netwtw10, Winlogon, Power-Troubleshooter, and Kernel-Boot.

System Number of events: 6,748					
Level	Date and Time	Source	Event ID	Task Ca...	
Error	2/9/2022 7:29:40 PM	DistributedCOM	10010	None	
Error	2/9/2022 7:29:40 PM	DistributedCOM	10010	None	
Warning	2/9/2022 7:23:00 PM	DistributedCOM	10016	None	
Information	2/9/2022 6:58:57 PM	Service Control Manager	7040	None	
Information	2/9/2022 6:56:47 PM	Service Control Manager	7045	None	
Information	2/9/2022 6:54:17 PM	Service Control Manager	7040	None	
Warning	2/9/2022 6:42:52 PM	DistributedCOM	10016	None	
Warning	2/9/2022 5:16:24 PM	Netwtw10	6062	None	
Warning	2/9/2022 5:16:12 PM	DistributedCOM	10016	None	
Warning	2/9/2022 5:16:12 PM	DistributedCOM	10016	None	
Information	2/9/2022 5:16:11 PM	Winlogon	7001	(1101)	
Information	2/9/2022 5:16:11 PM	Power-Troubleshooter	1	None	
Information	2/9/2022 5:16:09 PM	Kernel-Boot	27	(33)	
Information	2/9/2022 5:16:09 PM	Kernel-Boot	25	(32)	



SYSTEM LOGGING CONSIDERATIONS

- System logs of hosts and network devices must be time-synchronized
- IDS and sysadmin must be able to cross-correlate events
- Logging can be resource intensive for the device
 - If you are about to enable logging / OS auditing on a system for the first time, consider the impact of enabling the audit feature on system performance

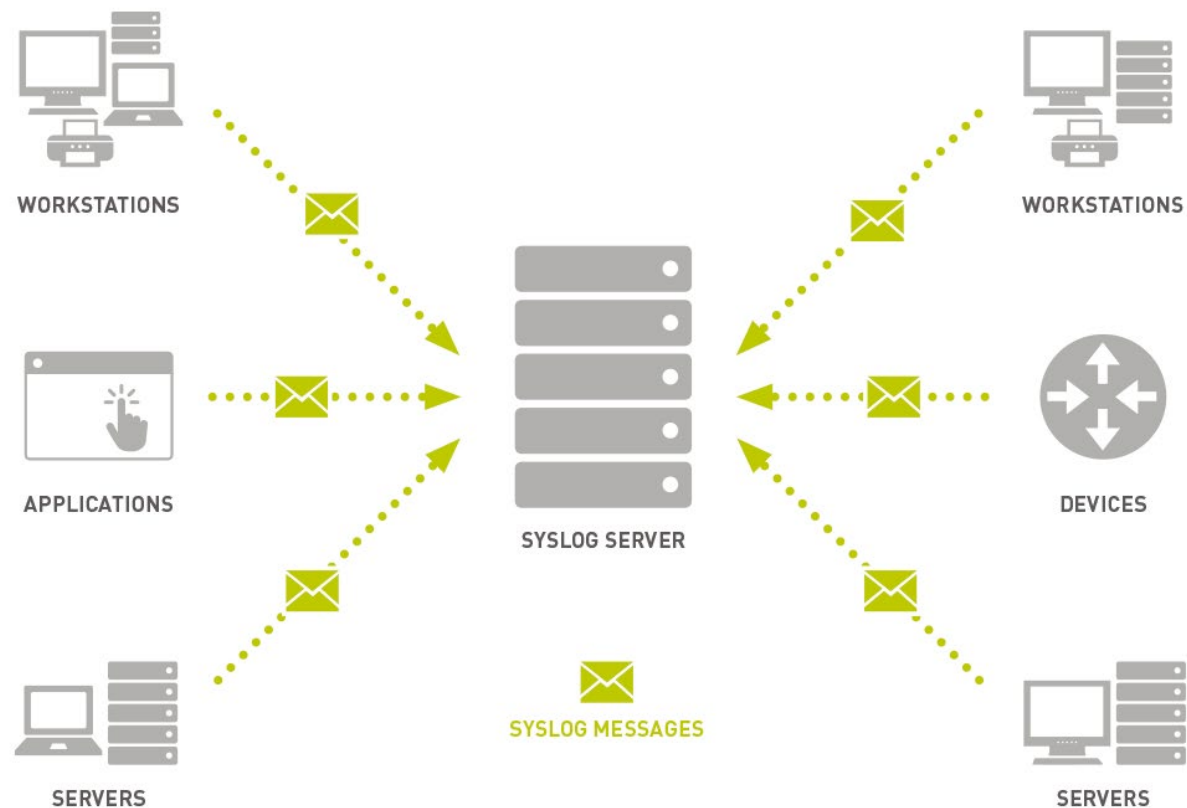


SYSLOG

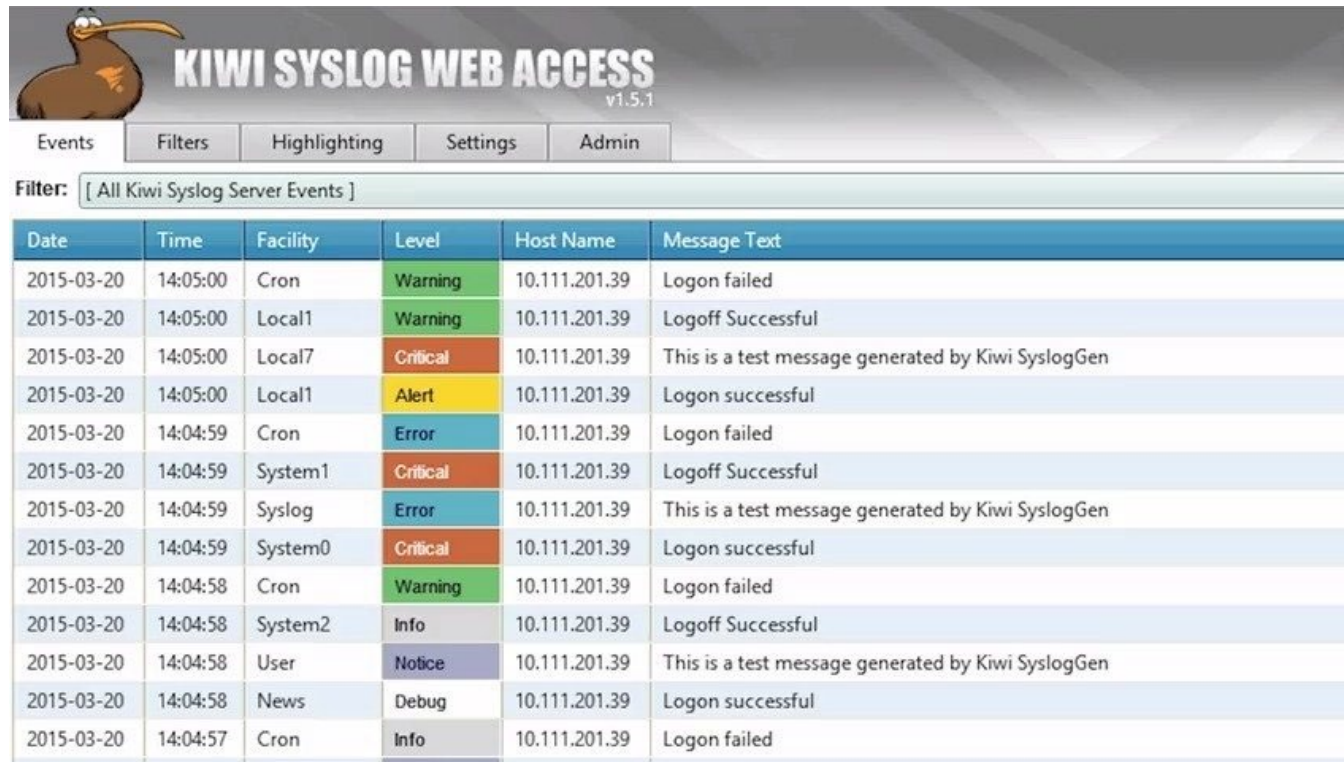
- Widely used standard for capture log messages from a variety of devices
 - Events are sent by devices to a centralized syslog server
 - Even if the attacker manages to delete logs on the compromised system, the syslog server has a copy
- Separates logging roles into:
 - Software that generates messages
 - The system that stores the messages
 - The software that analyzes the messages and creates reports
- Messages include:
 - time stamps, event messages, severity, host IP addresses, diagnostics, and more
- Kiwi syslog server is a popular syslog product
- Syslog uses UDP 514



SYSLOG EXAMPLE



KIWI SYSLOG SERVER EXAMPLE



The image shows the Kiwi Syslog Web Access v1.5.1 interface. At the top, there is a header with a kiwi bird logo and the title "KIWI SYSLOG WEB ACCESS v1.5.1". Below the header, there are navigation tabs: "Events", "Filters", "Highlighting", "Settings", and "Admin". The "Events" tab is selected. Below the tabs, there is a filter dropdown menu showing "[All Kiwi Syslog Server Events]". The main content area displays a table of syslog events.

Date	Time	Facility	Level	Host Name	Message Text
2015-03-20	14:05:00	Cron	Warning	10.111.201.39	Logon failed
2015-03-20	14:05:00	Local1	Warning	10.111.201.39	Logoff Successful
2015-03-20	14:05:00	Local7	Critical	10.111.201.39	This is a test message generated by Kiwi SyslogGen
2015-03-20	14:05:00	Local1	Alert	10.111.201.39	Logon successful
2015-03-20	14:04:59	Cron	Error	10.111.201.39	Logon failed
2015-03-20	14:04:59	System1	Critical	10.111.201.39	Logoff Successful
2015-03-20	14:04:59	Syslog	Error	10.111.201.39	This is a test message generated by Kiwi SyslogGen
2015-03-20	14:04:59	System0	Critical	10.111.201.39	Logon successful
2015-03-20	14:04:58	Cron	Warning	10.111.201.39	Logon failed
2015-03-20	14:04:58	System2	Info	10.111.201.39	Logoff Successful
2015-03-20	14:04:58	User	Notice	10.111.201.39	This is a test message generated by Kiwi SyslogGen
2015-03-20	14:04:58	News	Debug	10.111.201.39	Logon successful
2015-03-20	14:04:57	Cron	Info	10.111.201.39	Logon failed



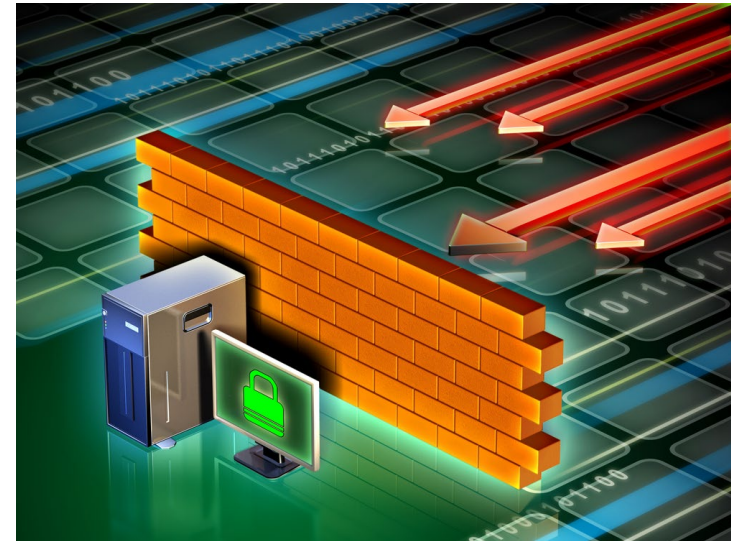
FIREWALLS

- Overview
- Stateless
- Stateful
- Circuit-level
- Application
- UTM



FIREWALL

- Acts as a network choke point
 - Traffic must flow through it
 - Unauthorized traffic (in or out) is blocked
- Can detect:
 - Unauthorized protocols
 - Unauthorized source and destination IP addresses
 - Unauthorized source and destination ports
 - Unauthorized incoming connection attempts
 - Malicious site URLs
 - Malicious payloads



If you can reach a host using one port or protocol but not another, suspect that a firewall is blocking certain traffic types.



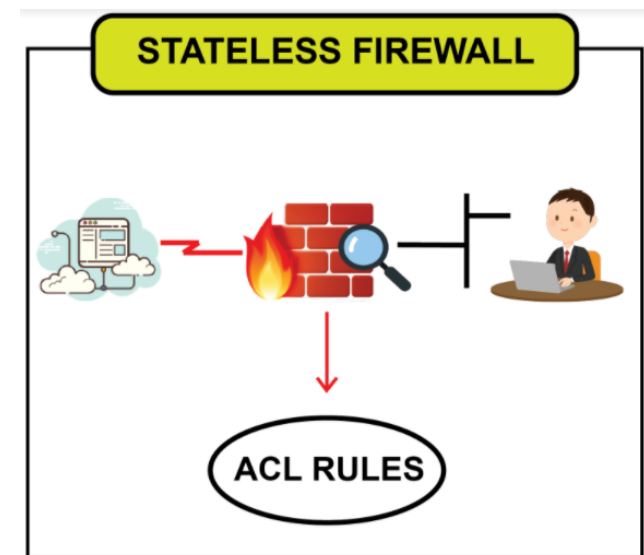
FIREWALL TYPES

- **Hardware-based**
 - AKA firewall appliance
 - Separate device
 - Placed at the network edge, between the “trusted” and “untrusted” networks
 - Blocks unauthorized traffic movement between the networks
- **Software-based**
 - Installed on a host
 - Prevents unauthorized traffic to/from the host itself



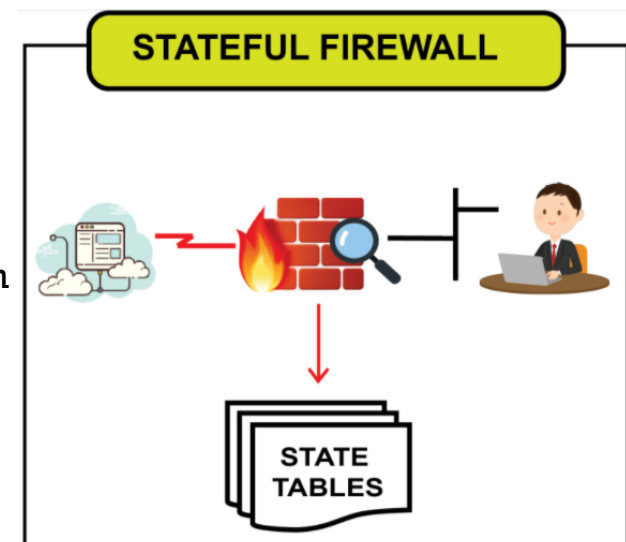
PACKET FILTERING/STATELESS FIREWALL

- Works at multiple OSI layers:
 - Layer 3 – IP addresses
 - Layer 4 – Protocol
 - Layer 5 – Ports
- Can be a stateless firewall or a packet filtering router
- Every packet is compared to a rule set
- Firewall can permit or deny the packet
- Rules may include:
 - IP address of source and/or destination
 - Port number of source and/or destination
 - Protocol (IP, ICMP, IGMP, TCP, UDP)
- There is no memory of the packet before
- You will have to configure rules for every contingency
- Best when high performance is critical



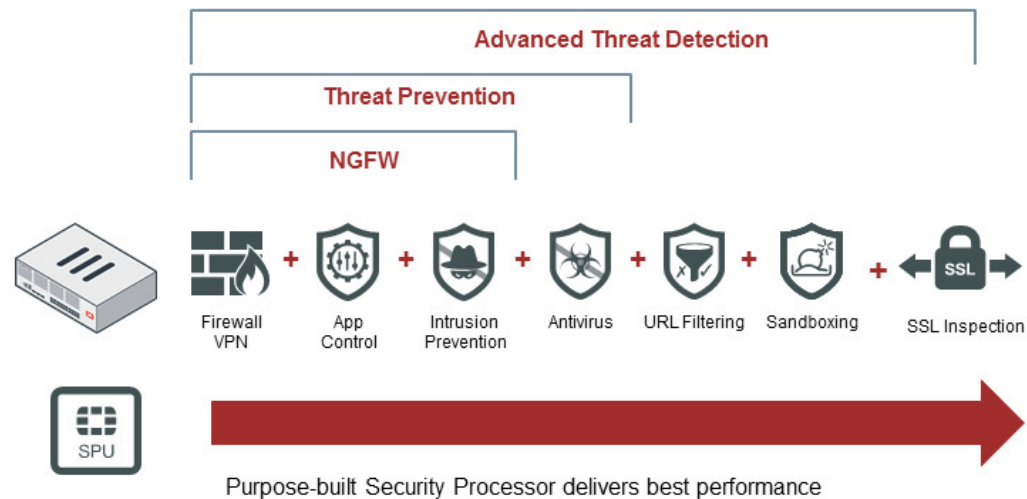
STATEFUL FIREWALL

- Maintains a **state table** for every connection
- **Disallows even outbound traffic if suspicious**
- **Tracks each connection**
- Will notice if:
 - There is no proper TCP handshake to start the connection
 - Any port suddenly changes
 - There are any other anomalies in the conversation
- **Filters packets at the network and transport layers**
- **Evaluates packet contents at the application layer**
- **Most modern firewalls are stateful**



UNIFIED THREAT MANAGEMENT (UTM)

- A device that combines multiple functions into a single piece of hardware including:
- Firewall
- Anti-malware
- URL filter
- Spam/phishing filter
- IDS/IPS
- VPN server
- Proxy
- Data Loss Prevention (DLP)



PACKET FILTERING RULES

- Rules Syntax
- Examples

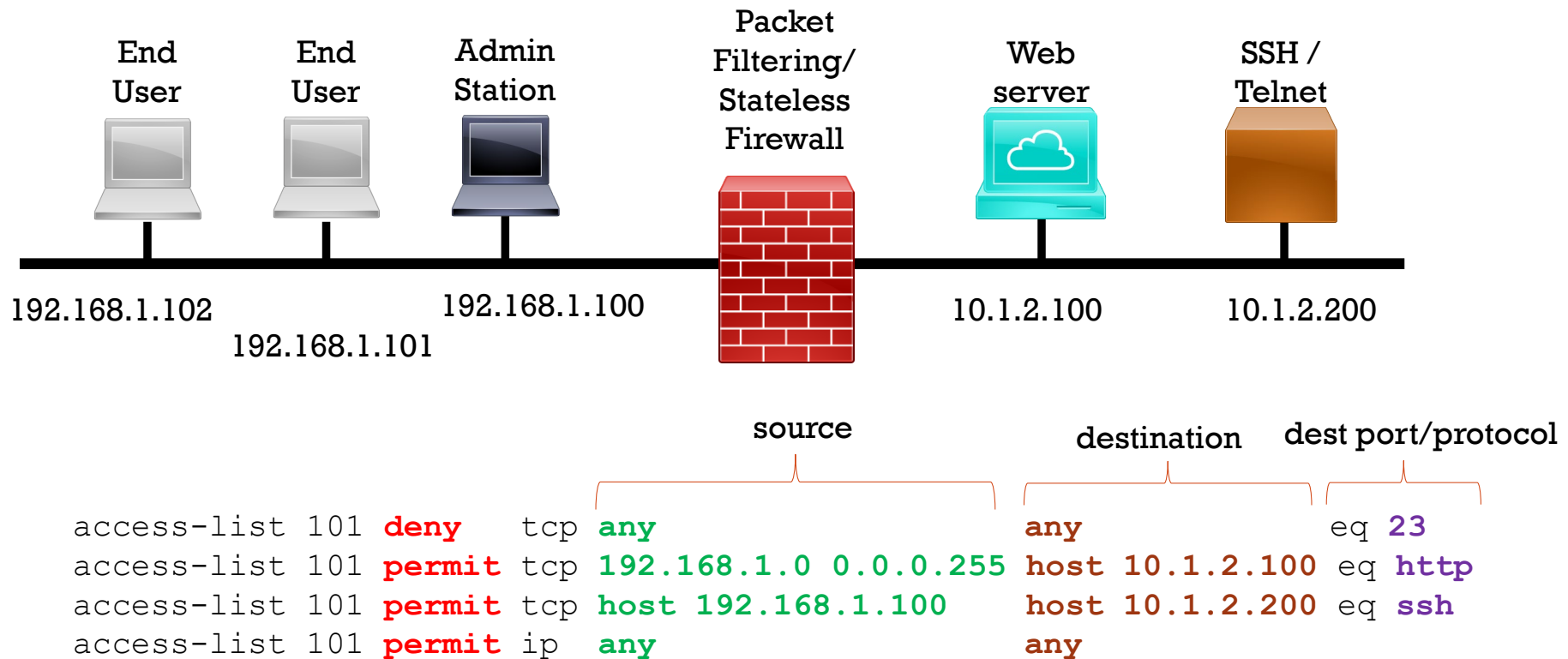


PACKET FILTERING RULE SYNTAX

- Different products have different rules syntax
- Typical rules elements include:
 - Action
 - Protocol
 - Source IP
 - Source port
 - Destination IP
 - Destination port
 - Connection state
 - Interface
 - Traffic direction (in or out of an interface)



CISCO PACKET FILTERING EXAMPLE



CISCO PACKET FILTERING RULE EXAMPLES

- **Disallow any source from pinging any destination**
 - `Deny ICMP any any`
- **Disallow any source from 192.168.1.0/24 from querying any DNS server**
 - `Deny UDP 192.168.1.0/24 any eq 53`
- **Only permit host 10.1.2.3 to use SSL/TLS connect to webserver 172.16.5.4**
 - `Permit TCP host 10.1.2.3 172.16.5.4 eq 443`



LINUX IP TABLES RULES EXAMPLE

- **Block a specific IP address**

- `BLOCK_THIS_IP="192.168.1.2"`

- `iptables -A INPUT -s "$BLOCK_THIS_IP" -j DROP`

- **Allow Incoming SSH only from a Specific Network**

- `iptables -A INPUT -i eth0 -p tcp -s 192.168.100.0/24 --dport 22 -m state --state NEW,ESTABLISHED -j ACCEPT`

- `iptables -A OUTPUT -o eth0 -p tcp --sport 22 -m state --state ESTABLISHED -j ACCEPT`



FIREWALL RULES SCENARIO

- You've been asked to review the firewall configuration to ensure that workstations in network 10.10.10.0/24 can only reach the bank web site 10.20.20.1 using https.
- Which rule satisfies the requirement?
- `if (source matches 10.10.10.0/24 and destination matches 10.20.20.1 and port matches 80 or 443) then permit`
- `if (source matches 10.20.20.1 and destination matches 10.10.10.0/24 and port matches 443) then permit`
- `if (source matches 10.10.10.0 and destination matches 10.20.20.1 and port matches 443) then permit`
- `if (source matches 10.10.10.0/24 and destination matches 10.20.20.1 and port matches 443) then permit`



FIREWALL RULES SCENARIO

- You've been asked to review the firewall configuration to ensure that workstations in network 10.10.10.0/24 can only reach the bank web site 10.20.20.1 using https.
- Which rule satisfies the requirement?
- if (source matches 10.10.10.0/24 and destination matches 10.20.20.1 and port matches 80 or 443) then permit
- if (source matches 10.20.20.1 and destination matches 10.10.10.0/24 and port matches 443) then permit
- if (source matches 10.10.10.0 and destination matches 10.20.20.1 and port matches 443) then permit
- if (source matches 10.10.10.0/24 and destination matches 10.20.20.1 and port matches 443) then permit



FIREWALL PRODUCT TYPES

- Host-based
- Appliances
- FWaaS



FIREWALL EXAMPLES

- Comodo
- Cisco ASA
- Check Point
- Untangle NG Firewall
- Sonicwall
- Online Armor
- FortiGate
- ManageEngine
- Perimeter 81
- Total AV
- VaultCore
- PC Protect
- Bitdefender
- McAfee
- ZoneAlarm PRO
- Windows Defender
- Linux iptables
- Linux UFW
- Cisco packet filtering router
 - Outside firewall to create a “Dirty” DMZ

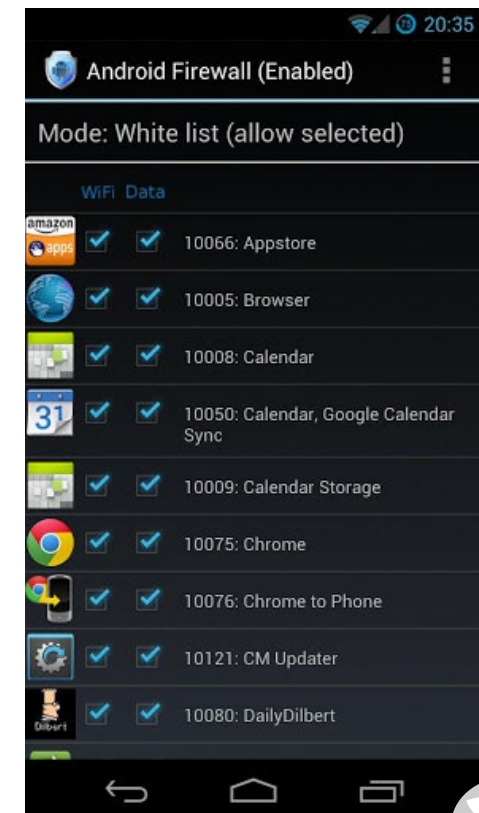


HARDWARE FIREWALL EXAMPLES



FIREWALLS FOR MOBILE

- Android Firewall
- Firewall iP
- Mobiwol: NoRoot Firewall
- DroidWall
- AFWall+
- Firewall Plus
- Root Firewall
- Android Firewall Gold
- Droid Firewall
- Privacy Shield
- aFirewall
- NoRoot Firewall



CLOUD-BASED IDS AND FIREWALL SERVICES

- IDSaaS
 - Google Cloud IDS
 - AlienVault
 - Checkpoint
- FWaaS
 - Perimeter 81
 - Fortinet
 - Zscaler

